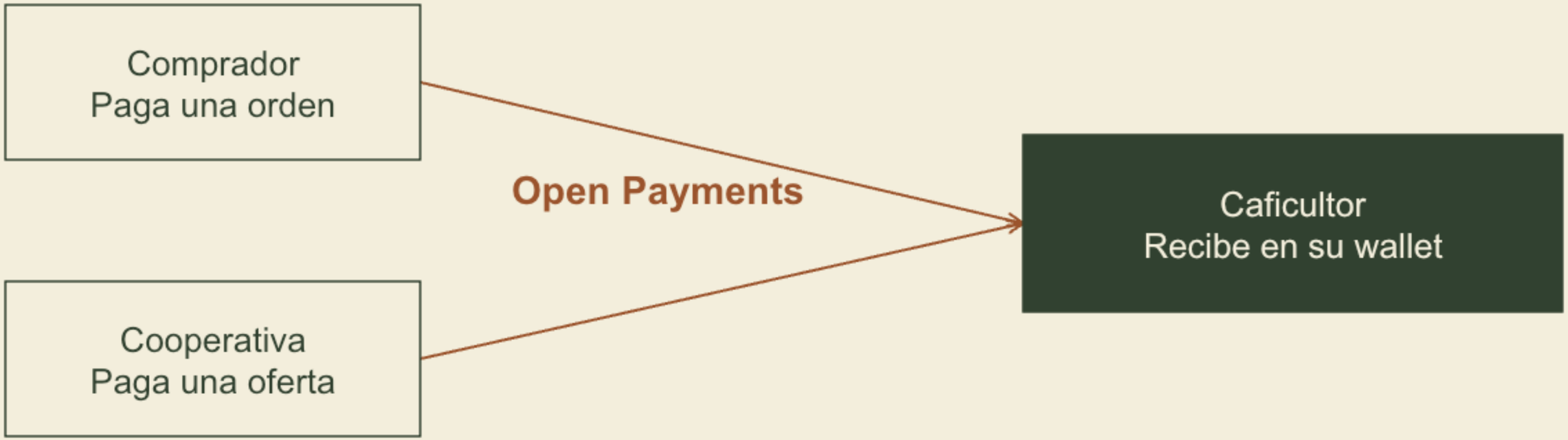
TERRACIERTA

Pagos con evidencia postcuántica

Ciberseguridad de la pasarela de café

Hackathon Open Payments · Medellín · 2026

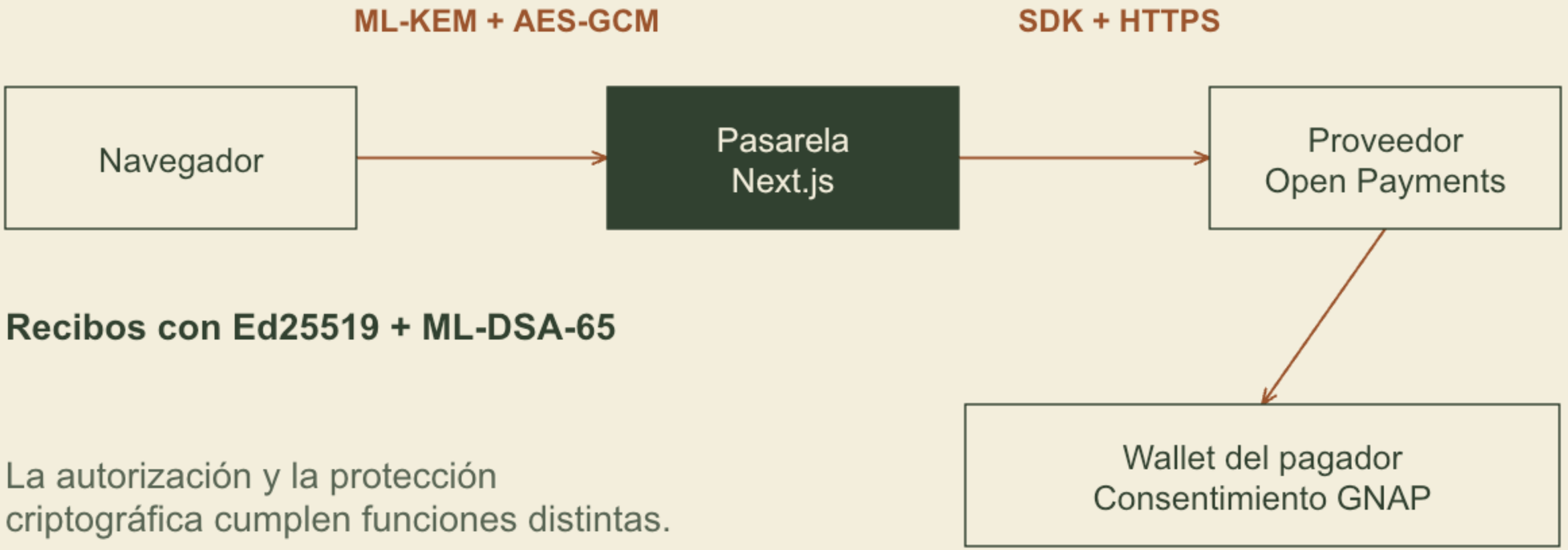
El café llega al comprador. El pago llega al productor



Quien paga autoriza en su wallet

El productor consulta su cobro sin aprobar la recepción.

Dónde termina la protección PQC de la app



Recibos con Ed25519 + ML-DSA-65

La autorización y la protección criptográfica cumplen funciones distintas.

Nueve riesgos orientan el diseño

Riesgo	Control o respuesta	Estado del prototipo
R01 · Autoridad de claves	Separación de secretos y ejecución	Pendiente en infraestructura
R02 · Cobro incierto	Bloqueo de reenvío y consulta	Parcial, estado aún en memoria
R03 · Monto o receptor	AEAD + validación de negocio	Implementado y probado
R04 · Replay y retorno	Request ID, estado GNAP y sesión	Implementado, alcance local
R05 · Wallet ajena	Perfil del servidor y propiedad	Pruebas con adaptadores
R06 · Claves falsas	Firma híbrida y claves esperadas	Raíz de confianza pendiente
R07 · Saturación	Límites de cuerpo y frecuencia	Sin prueba de carga completa
R08 · JS malicioso	Reducir confianza en el cliente	Riesgo residual
R09 · Descifrado futuro	ML-KEM en la capa de aplicación	Alcance navegador–pasarela

Canal de aplicación con ML-KEM-768

Encapsulate(pk) = (ct, ss)

Decapsulate(ct, sk) = ss

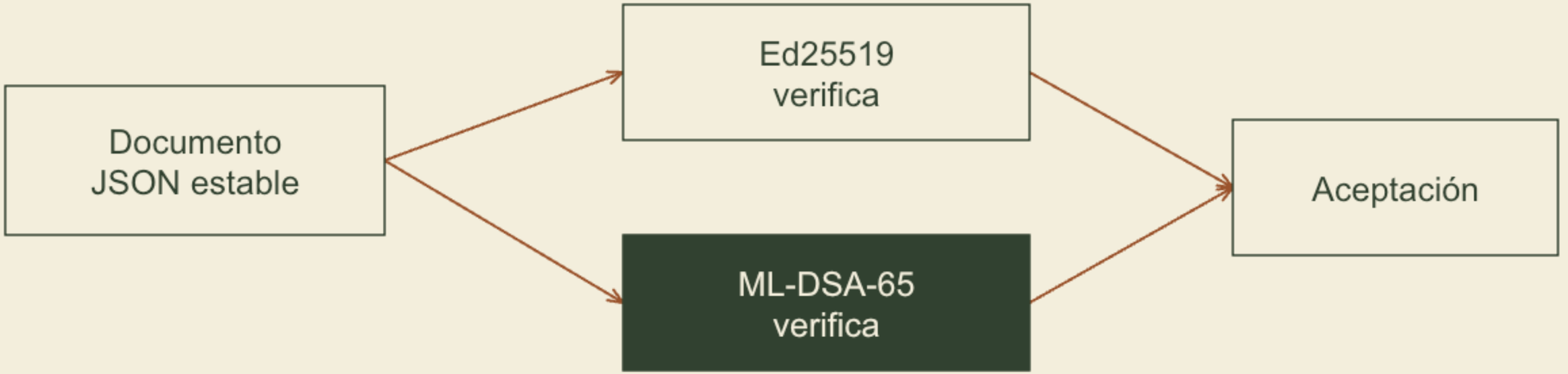
Kreq = HKDF-SHA-256(ss, dominio : request)

Kresp = HKDF-SHA-256(ss, dominio : reply)

C, tag = AES-256-GCM(K, IV, mensaje, AAD)

AAD vincula ruta, dirección, request ID, clave y tiempo.
IV de 96 bits. Tag de autenticación de 128 bits.

Un recibo exige ambas firmas y el negocio correcto



Aceptar = Ed válida ∧ ML-DSA válida ∧ negocio coincide

Claves públicas y firmas medidas en bytes

Ed25519: 32 / 64 ML-DSA-65: 1952 / 3309

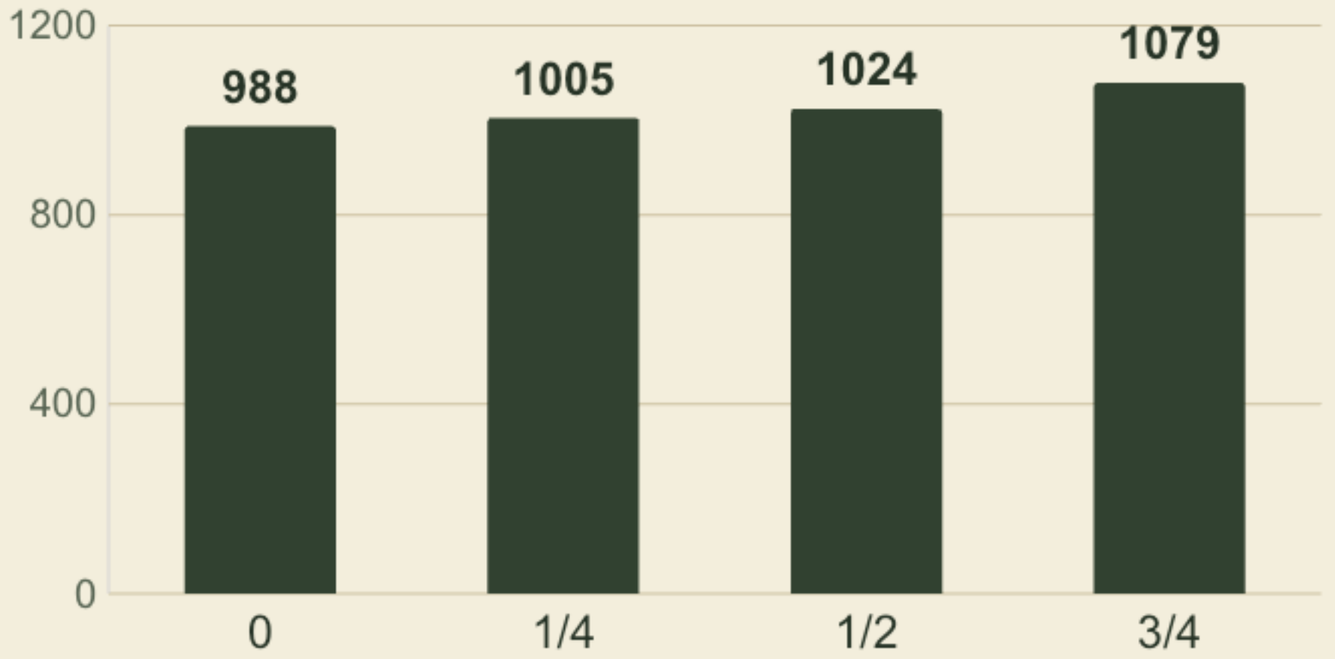
El escudo compara resultados reproducibles

Experimento	Cálculo real	Supuesto explícito
Confidencialidad	ECDH y ML-KEM, AES-GCM Ida y vuelta y bit alterado	El atacante obtiene la clave ECDH de prueba
Integridad	Receptor modificado y firma Ed ML-DSA detecta la alteración	El atacante obtiene la clave Ed25519 de prueba

Claves nuevas. Mismo caso al cambiar el escudo.

El laboratorio muestra una consecuencia bajo un supuesto de compromiso.
La resistencia de los algoritmos requiere análisis criptográfico externo.

Shor: una simulación pequeña con resultados reales



N = 15 a = 2
r = 4
gcd(2² ± 1, 15)
= 3 y 5

12 qubits lógicos
4096 mediciones

Simulador local ideal. Este caso educativo no ataca una clave de producción.

La evidencia acompaña a la animación

Código y pruebas automatizadas

188 pruebas pasan y 23 quedan omitidas.
Pago testnet completado con consentimiento.

Burp Suite

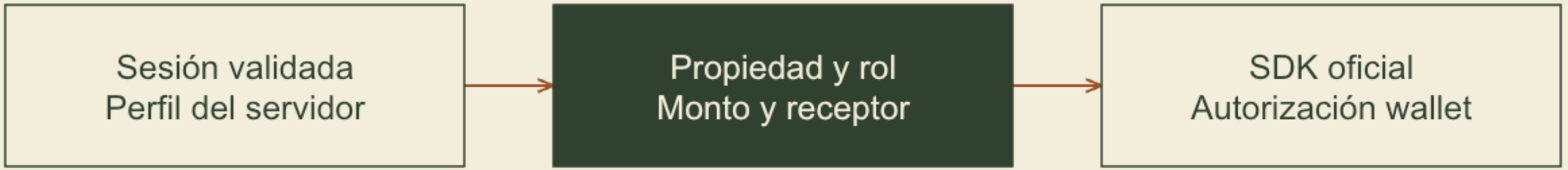
MCP: key 200 y echo 200.
Echo alterado: 400.
Sin repetir pagos.

Node + OpenSSL

9 comprobaciones de interoperabilidad.
2 límites de confianza y ciclo de claves.

Las pruebas verifican propiedades concretas. La suite no certifica toda la plataforma.

El login entrega identidad. La pasarela aplica permisos



Perfil: usuario + rol + wallet

La orden u oferta determina el precio y el destino en el servidor.
El caficultor recibe y consulta. El pagador autoriza el gasto.

Integración reproducible: npm ci y el handoff técnico del repositorio

Qué existe y qué requiere producción

Implementado

Canal ML-KEM y AES-GCM
Recibos Ed25519 + ML-DSA
Controles de negocio y GNAP
Pago autónomo testnet completado
Laboratorio verificable

Pendiente de integración e infraestructura

Login real y wallets compatibles
Estado durable de pagos y grants
Custodia, rotación y raíz de claves
HTTPS y operación del servicio

Algoritmos estandarizados por NIST. Esta implementación no posee certificación FIPS ni PCI DSS.

La demostración para el jurado

Una pasarela simple para quien compra café

Un laboratorio que explica el riesgo y permite repetir la prueba

Una evidencia verificable de cifrado, firmas y validación

/pago/pasarela
/pago/seguridad

La innovación une una amenaza futura con controles actuales y límites comprobables.